LABORATUVAR 5 · CMAK KÖPRÜLÜ VINÇ · Tek Kirişli Köprülü Vinç (SAMİB)

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad YUSUF DURSUN · 230541104 **Grup** GÜNDÜZ B **Tarih**

Kavram: SBOM = yazılım malzeme listesi · CVE = açığın kayıt no'su · CVSS = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir.**

Verilen zafiyet kaydı	
Bileşen	Component X (vinç PLC firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

- **Bileşen var mı?** Üreticiden (Çakmak Vinç) alınan SBOM'da PLC firmware'inde Component X görünüyor → **Evet**.
- **Sürüm etkileniyor mu?** Kurulu sürüm 2.4; CVE bülteninde etkilenen aralık 2.4'ü kapsıyor → **Evet**.
- **Ulaşılabilir mi?** Açığı tetikleyen servis vinç ağında açık ve 4G modül internete açık → **Evet**.

Sonuç: Üç şart da sağlanıyor → bizi etkiliyor; CVSS 9.8 ile **acil**.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Otomatik olarak hayır — önce ulaşılabilirliği hemen keseriz: 4G modülün bağlantısı fiziksel olarak ayrılır, Wi-Fi kapatılır, USB'ler kilitlenir. Vinç izole çalışabilir. CVSS tek başına durdurma sebebi değildir.
Ancak aktif istismar belirtisi varsa veya açık aşırı yük/limit fonksiyonunu etkiliyorsa vinç **yük indirilerek kullanım dışı bırakılır** ("kullanılamaz" etiketi) ve emniyet doğrulanmadan çalıştırılmaz.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Yama üretici (Çakmak Vinç) tarafından onaylanmalı. Test yeri: üreticinin test panosu / aynı PLC ve inverterlere sahip test düzeneği. Ardından planlı duruşta, vinç yüksüz iken, program ve parametre yedeği alınıp geri dönüş planı hazırken uygulanır; sonra fonksiyon ve yük testleri yapılır.

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Etki analizi ile: (a) Component X Safety PLC'de, aşırı yük veya limit fonksiyonunda kullanılıyor mu? (SBOM + üretici sürüm notları) (b) Safety PLC programının checksum'ı değişiyor mu? (c) Kalibrasyon, eşik veya fren parametreleri etkileniyor mu?
Etkiliyorsa: değişiklik yönetimi + yeniden validasyon: test ağırlığıyla aşırı yük kesmesinin doğrulanması, kaldırma ve ray sonu limit testleri, fren tutma testi, telsiz ve pano acil stop testleri, imzalı kayıt (gerekirse yetkili kişi periyodik kontrolü).
Yalnız hareket PLC'sini etkiliyorsa: belgelenmiş etki analizi + fonksiyon testleri.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- 4G/internet bağlantısı kesilir; uzak erişim yalnız VPN + jump server + MFA ile ve varsayılan kapalı açılır
- Güvenlik duvarında zafiyetli servise erişim engellenir; kullanılmıyorsa servis kapatılır
- Ağ segmentasyonu, anomali izleme, log alarmı; USB kilidi, HMI port 80 kapatma
- Vardiya başı aşırı yük ve limit kontrolü (kontrol listesi), donanımsal son limitin doğrulanması
- Risk kabul kaydı (sorumlu + son tarih) ve yamanın planlanması

📄 Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.